DG INTERNS HUB / CYBERSECURITY INTERNSHIP

WEEK 08

ADVANCED VAPT

Attack Surface • Security Testing
Findings • Remediation • Retesting

ASSESSMENT TARGET

OWASP Juice Shop

Authorized local training lab | 127.0.0.1:3000

PREPARED BY	**Samyuktha S.**
INTERNSHIP ID	**DG/SEPTEMBER/CYBER/102**
PROJECT	**Advanced VAPT — Attack Chain & Findings**
REPORT DATE	**27 October 2026**

ASSESSMENT STATUS

Findings documented | Remediation and retesting pending verification

1. Executive Summary

This assessment reviewed the intentionally vulnerable OWASP Juice Shop application in a controlled local lab. Evidence included application access and route discovery, Burp Suite request/response inspection, authentication checks, product-search input handling, and registration role assignment. Two findings are documented: F-01, SQL-related error disclosure in product search; and F-02, acceptance of a client-supplied administrator role during registration.

ID	Finding	Observed evidence	Provisional severity	Remediation status
F-01	SQL Error Disclosure in Product Search	Apostrophe input produced HTTP 500 with SQLite/query/stack details.	Medium (provisional)	Pending Verification
F-02	Admin Role Assignment During Registration	Registration with role=admin returned HTTP 201 and admin role; challenge success shown.	High potential impact (provisional)	Pending Verification

The evidence confirms the observed behaviors in the local training application. F-01 does not prove exploitable SQL injection or database extraction. F-02 does not prove that protected administrative operations were accessed. The two findings arose from separate tests; a combined exploitation chain was not demonstrated. Remediation and retesting for both findings remain Pending Verification.

2. Scope, Authorization & Limitations

In scope: local Juice Shop routes and functionality, authentication/session behavior, product-search input/error handling, public registration role assignment, HTTP traffic inspected with Burp Suite, evidence documentation, and remediation planning. Out of scope: public/third-party systems, unauthorized targets, denial-of-service testing, destructive testing, and unsupported impact claims.

The archive identifies the target as http://127.0.0.1:3000. Tool versions, exact application build, and test timestamps were not established from the supplied documentation, so they are not invented here.

3. Methodology & Evidence Handling

The documented workflow was: planning and scope definition; application access and route discovery; request/response inspection; authentication and session checks; normal and special-character product searches; registration role-assignment test; finding assessment; remediation planning. The report references original screenshots by their exact filenames. Evidence is kept in the supplied project folders; no screenshots were renamed.

4. Attack Surface & Authentication Checks

The archive contains screenshots of initial Juice Shop access, login and registration pages, Burp browser access, the Burp site map, security-questions and quantity API requests, login request/response pairs, and authenticated/unauthenticated whoami checks. The route inventory confirms the home, login, and registration pages and records the local target URL. Other routes should only be described as observed where supported by the Burp site-map evidence.

Test	Observed result	Interpretation
T-01 Invalid credentials	HTTP 401 Unauthorized	Expected invalid-login behavior; no vulnerability demonstrated.
T-02 Successful login	HTTP 200 with authentication data	Successful authentication observed.
T-03 Authenticated whoami	HTTP 200 OK	Authenticated identity request responded.
T-04 whoami without Cookie header	HTTP 200 with empty user object	No user-data exposure demonstrated.

5. Finding F-01 — SQL Error Disclosure in Product Search

Affected endpoint: GET /rest/products/search?q=...

Observed behavior: Normal input (`test`) returned HTTP 200. Apostrophe input (`test'`) and URL-encoded apostrophe (`test%27`) produced HTTP 500 with SQLite syntax error details, stack information, and the generated SQL query visible in the response, according to the test matrix and finding notes.

Security significance: Internal database implementation details and query-related information are disclosed to the client. The behavior suggests unsafe query construction or inadequate error handling, but the evidence does not demonstrate successful SQL injection, unauthorized data retrieval, or data modification.

Severity: Medium (provisional). Confirm against the internship/project risk rubric and any additional authorized validation.

Evidence: `E13-Product-Search-Baseline.png`, `E14-Product-Search-Special-Input.png`, `E15-Product-Search-Normal-Input.png`.

Recommended remediation

1. Use prepared statements / parameterized queries; do not construct SQL through concatenation of user-controlled values. 2. Return generic client-facing errors. 3. Keep detailed SQL errors and stack traces in secure server-side logs. 4. Review related query paths. 5. Regression-test normal searches and special-character inputs to ensure searches still work and no database internals are disclosed.

6. Finding F-02 — Admin Role Assignment During Registration

Endpoint: POST /api/Users/

Observed behavior: The registration request included a client-supplied `role: admin` field. The local application returned HTTP 201 Created and the response included `role: admin`. The OWASP Juice Shop interface displayed a success message for the Admin Registration challenge. The account identity was also checked using an authenticated whoami request, but that response did not itself establish the account role.

Security significance: Public registration should not permit a client to choose a privileged role. If the same behavior existed in a production system, it could allow unauthorized privilege assignment. The actual administrative operations available to this account were not independently tested, so protected admin access is not claimed.

Severity: High potential impact (provisional); validate using the assessment rubric and system context.

Evidence: `E09-Registration-Request-Response.png` in `03-Burp-Evidence/`, `F-02-Admin-Role-Registration.png` in `05-Findings/`, and `F-02-Admin-Registration-Challenge-Solved.png` in `03-Burp-Evidence/`.

Recommended remediation

1. Assign the default customer role on the server during public registration. 2. Reject or ignore client-supplied privilege fields such as `role: admin`, `isAdmin`, or equivalent attributes. 3. Enforce authorization server-side on every administrative operation. 4. Add automated tests for role tampering during registration. 5. Review existing accounts and registration audit events where appropriate.

7. Attack-Chain Interpretation & Limitations

The test sequence moved from local application reconnaissance to authentication/session checks and then product-search input testing, which produced F-01. F-02 was a separate registration test that demonstrated acceptance of a client-supplied admin role and challenge completion. These are separate paths in the evidence. No combined F-01-to-F-02 exploitation chain was demonstrated.

The `/rest/products` request returning an “Unexpected path” error was treated as an invalid endpoint rather than a vulnerability. A cookie-free whoami request returned an empty user object, and no user-data exposure was demonstrated.

8. Remediation & Retesting Plan

All remediation and retesting statuses below are Pending Verification. No fixes are claimed as applied and no successful retests have been recorded. Actual results are left as “Not yet tested” until fresh evidence exists.

F-01 retest criteria

Test ID	Acceptance criteria	Actual result	Status
F01-RT-01	Normal search returns expected results without regression.	Not yet tested	Pending Verification
F01-RT-02	Apostrophe input does not disclose SQL errors, query text, or stack traces.	Not yet tested	Pending Verification
F01-RT-03	Encoded apostrophe is handled safely without internal error disclosure.	Not yet tested	Pending Verification
F01-RT-04	Implementation uses parameter binding for the search term.	Not yet tested	Pending Verification

F-02 retest criteria

Test ID	Acceptance criteria	Actual result	Status
F02-RT-01	Registration without a role field creates a customer account.	Not yet tested	Pending Verification
F02-RT-02	Registration with role=admin is rejected or ignored; no admin role is granted.	Not yet tested	Pending Verification
F02-RT-03	Customer account is denied protected administrative operations.	Not yet tested	Pending Verification
F02-RT-04	Server-side authorization is enforced on administrative endpoints.	Not yet tested	Pending Verification

Retest records should include date, environment/build, exact request and response, actual result, and a new evidence filename. A finding should only be closed after the relevant acceptance criteria pass and the result is supported by genuine evidence.

9. Risk Mapping & Conclusion

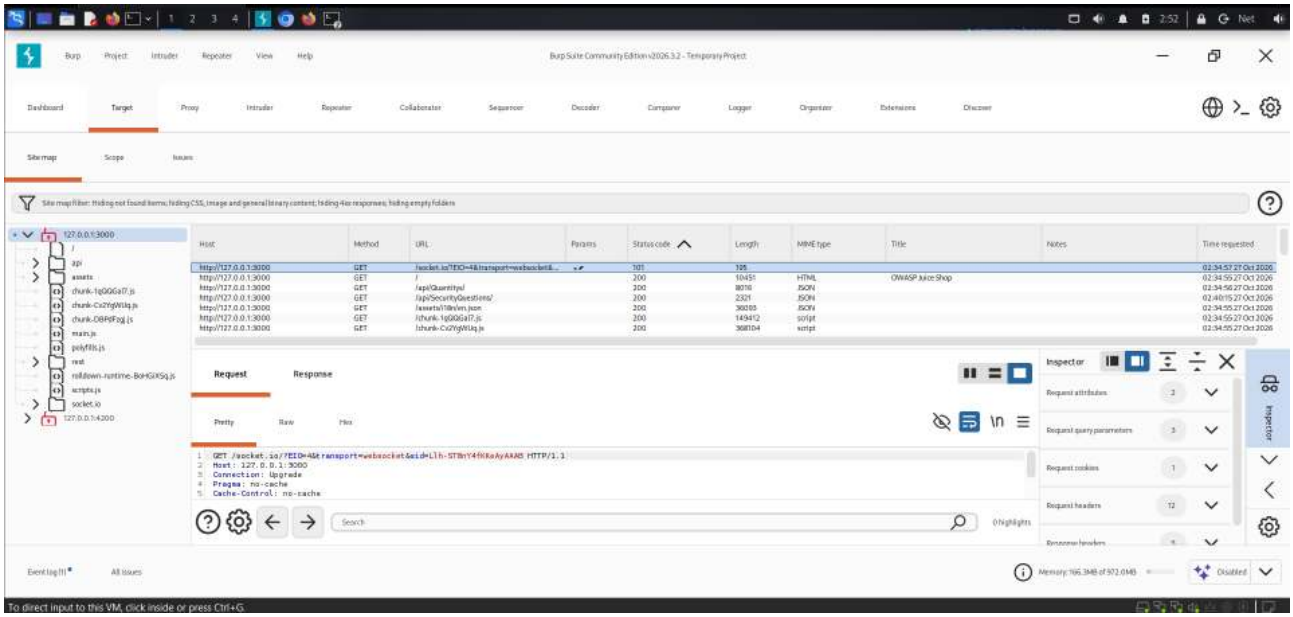
F-01 is primarily an error-disclosure observation, provisionally mapped to security misconfiguration; injection is an investigation lead only. F-02 relates to broken access control / improper attribute assignment because a client-supplied role was accepted during registration. Severity ratings are provisional and should be reviewed against the project’s formal rubric.

The assessment identified two meaningful security weaknesses in the intentionally vulnerable local lab: SQL-related error disclosure in product search and client-controlled role assignment during registration. Parameterized queries, safe error handling, server-controlled role assignment, and server-side authorization checks are recommended. Remediation and retesting for both findings remain Pending Verification.

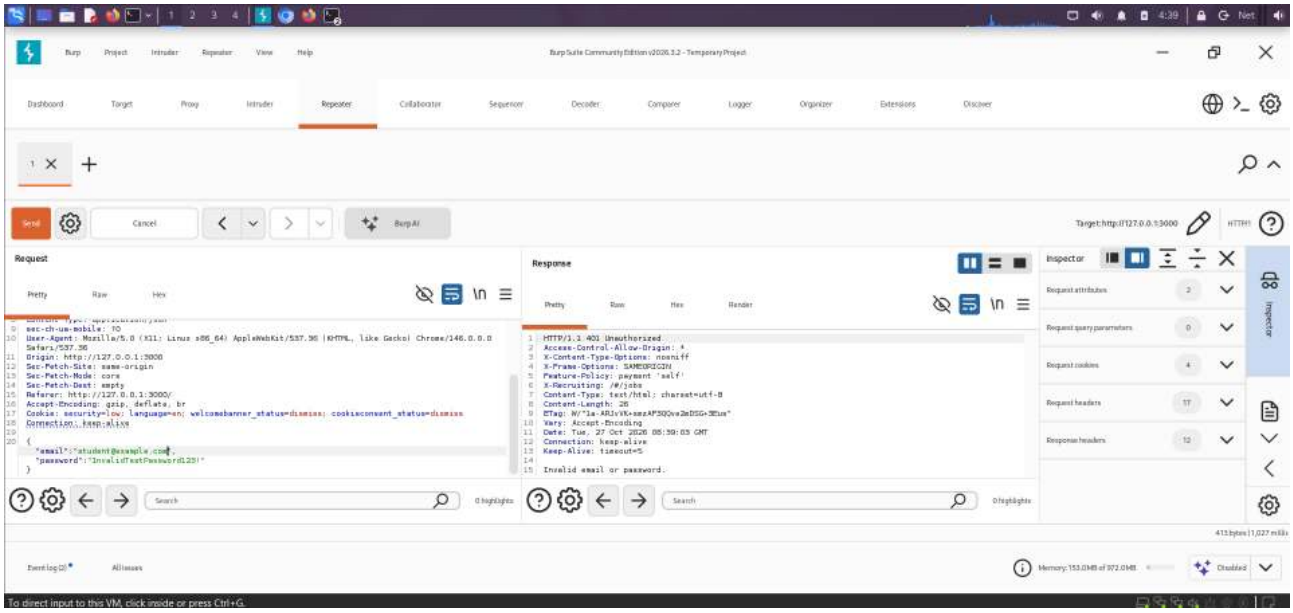
Appendix A — Selected Evidence Screenshots

Screenshots below are included from the supplied archive. Inspect and redact any sensitive values before sharing the report outside the lab/submission context.

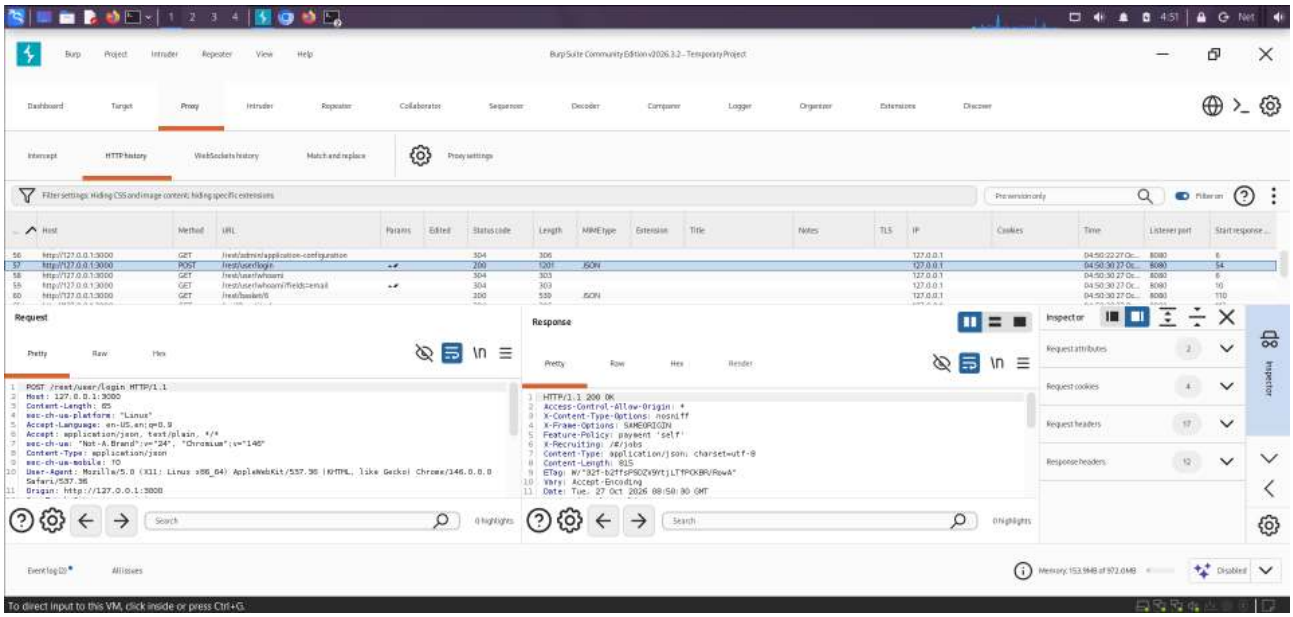
E02-Burp-Site-Map.png



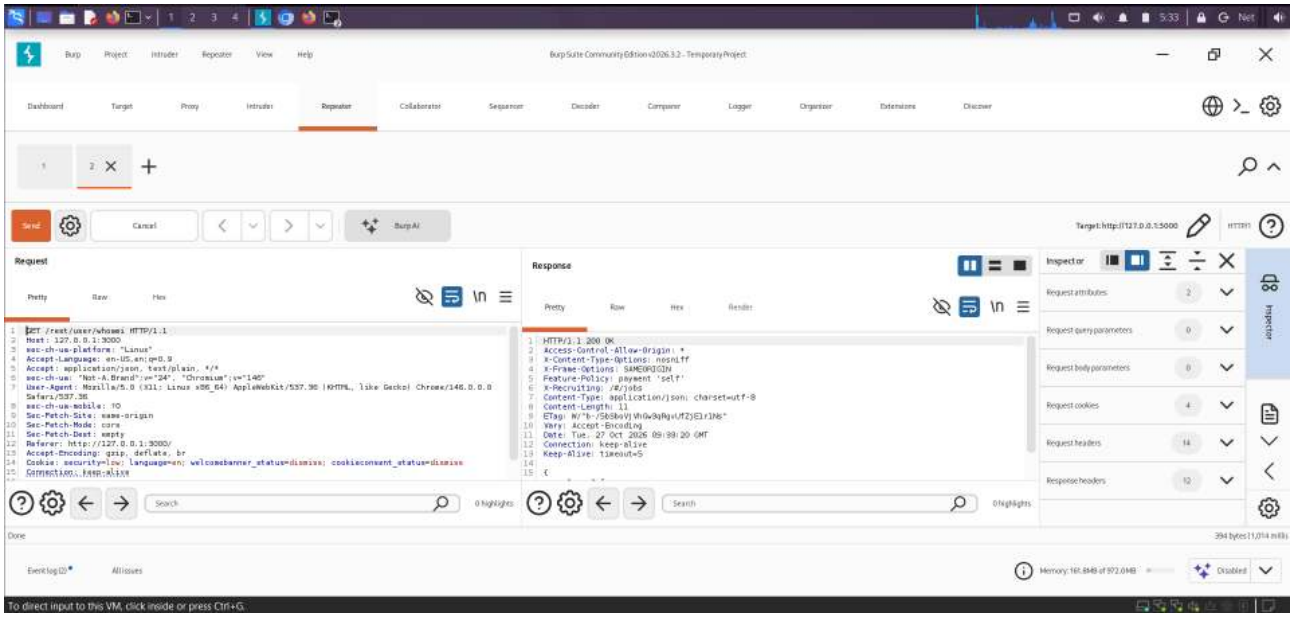
E08-Login-Invalid-Credentials-Comparison.png



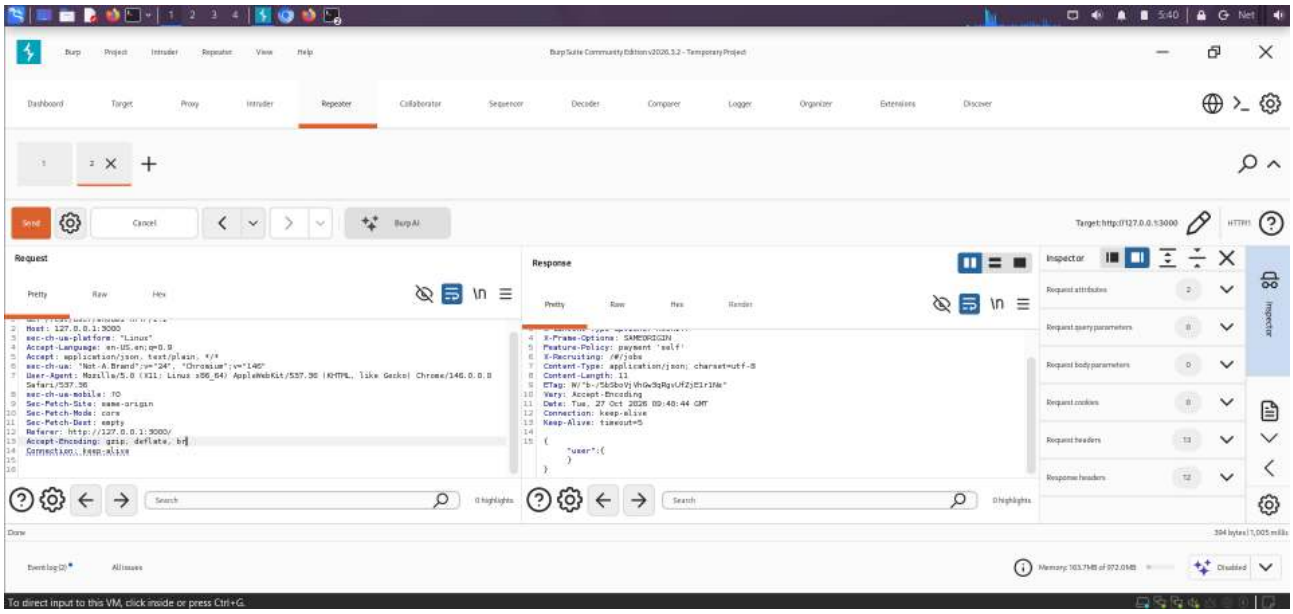
E09-Registration-Request-Response.png



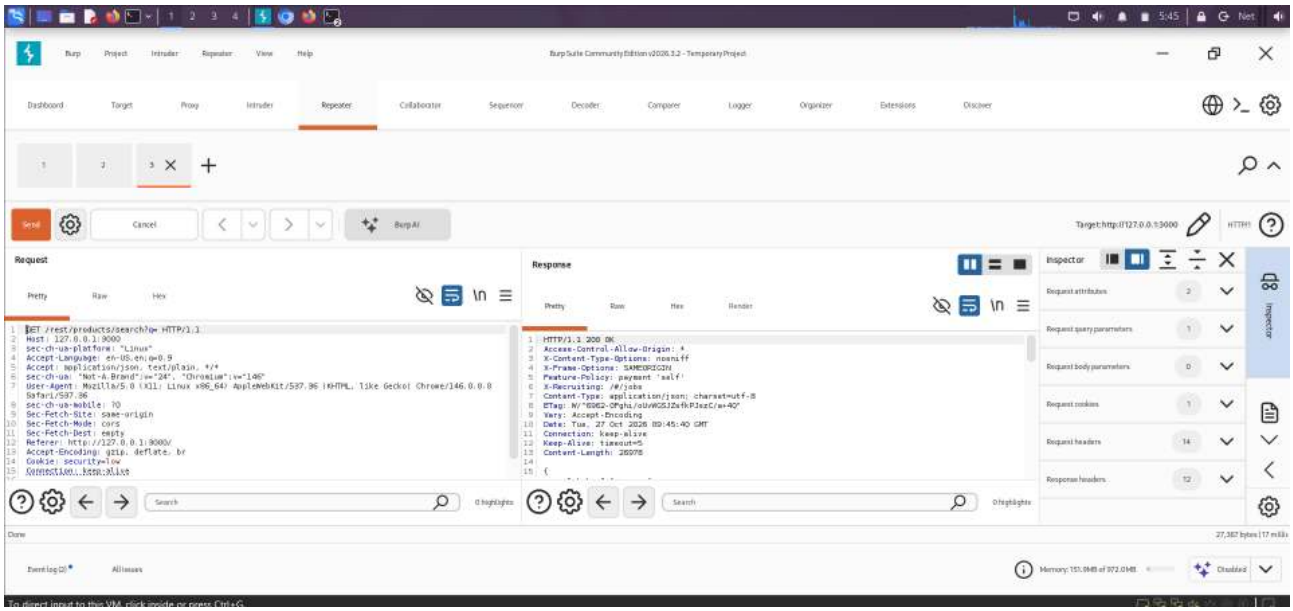
E11-Whoami-Authenticated-Baseline.png



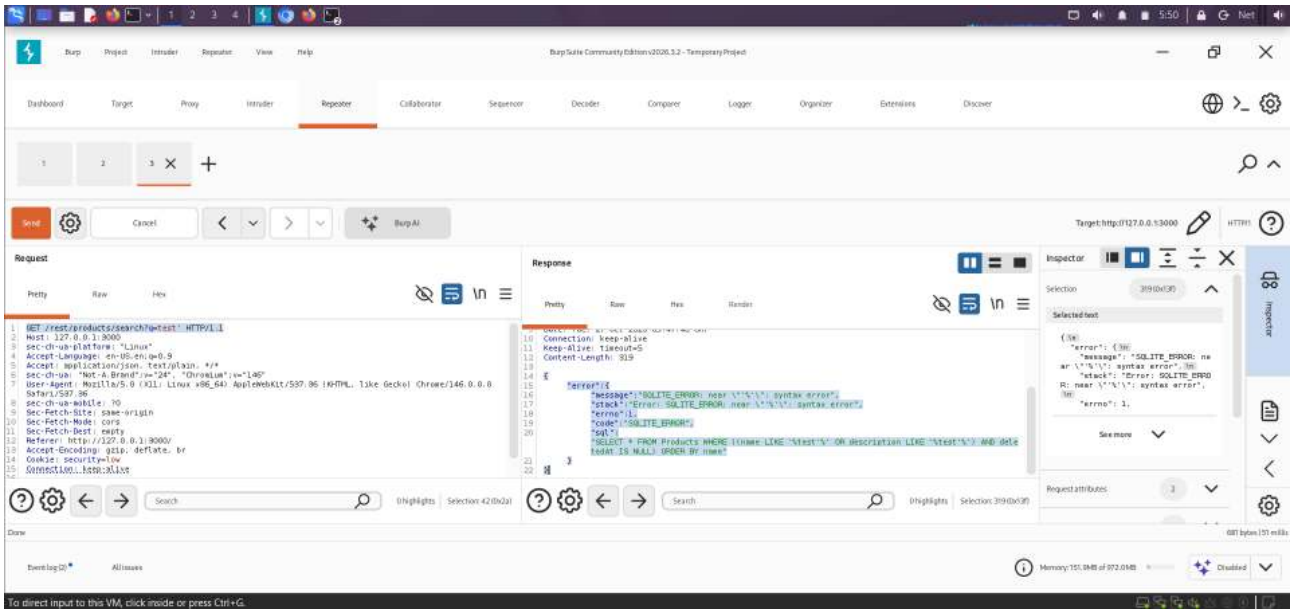
E12-Whoami-Unauthenticated-Test.png



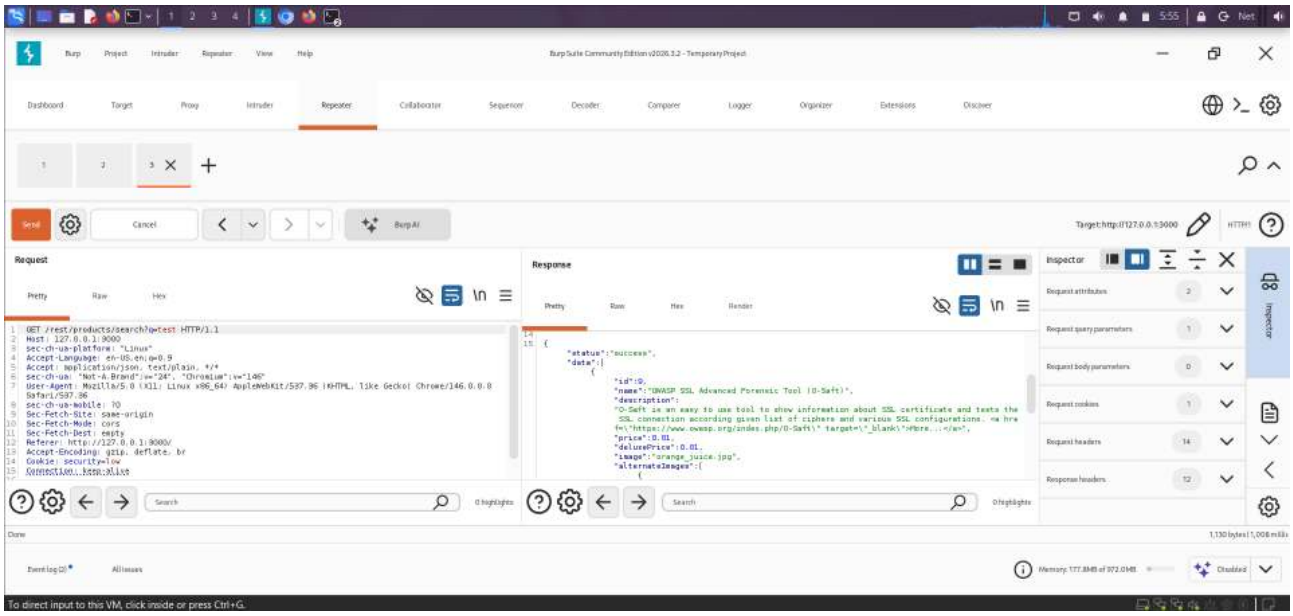
E13-Product-Search-Baseline.png



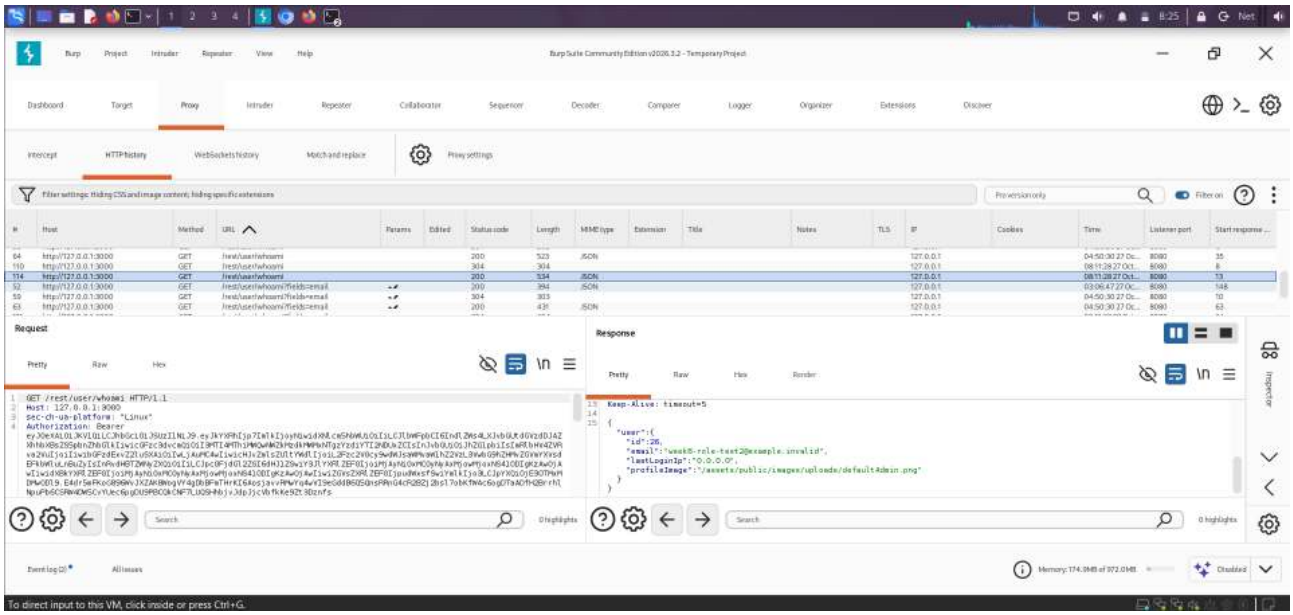
E14-Product-Search-Special-Input.png



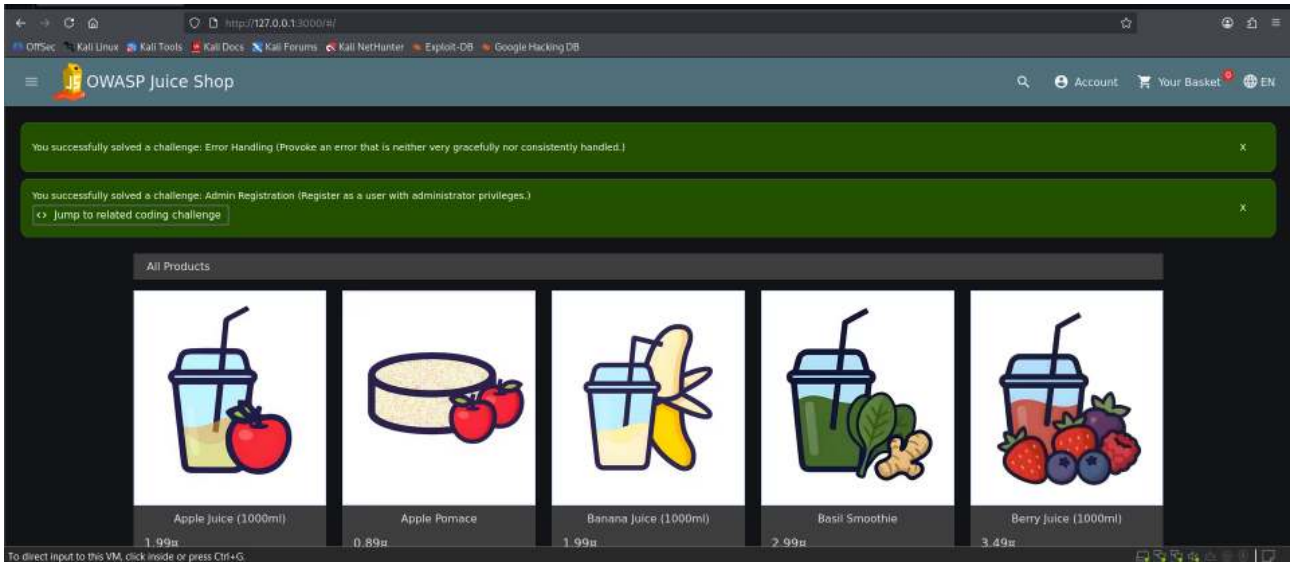
E15-Product-Search-Normal-Input.png



F-01-Authenticated-Account-Verification.png



F-02-Admin-Registration-Challenge-Solved.png



F-02-Admin-Role-Registration.png

